

SECURITY IN PERSPECTIVE

Introduction to Computer and Network Security

Silvio Ranise [silvio.ranise@unitn.it or ranise@fbk.eu]



UNIVERSITÀ
DI TRENTO



- Attacks, the CIA triad, and impact
 - Scale of attacks
 - Attribution problem
- Some examples of security services
- Security vs Privacy
- Some examples of privacy preserving techniques
- Risk based privacy and legal constraints
- Security and human factors

CONTENTS





ATTACKS, THE CIA TRIAD, AND IMPACT

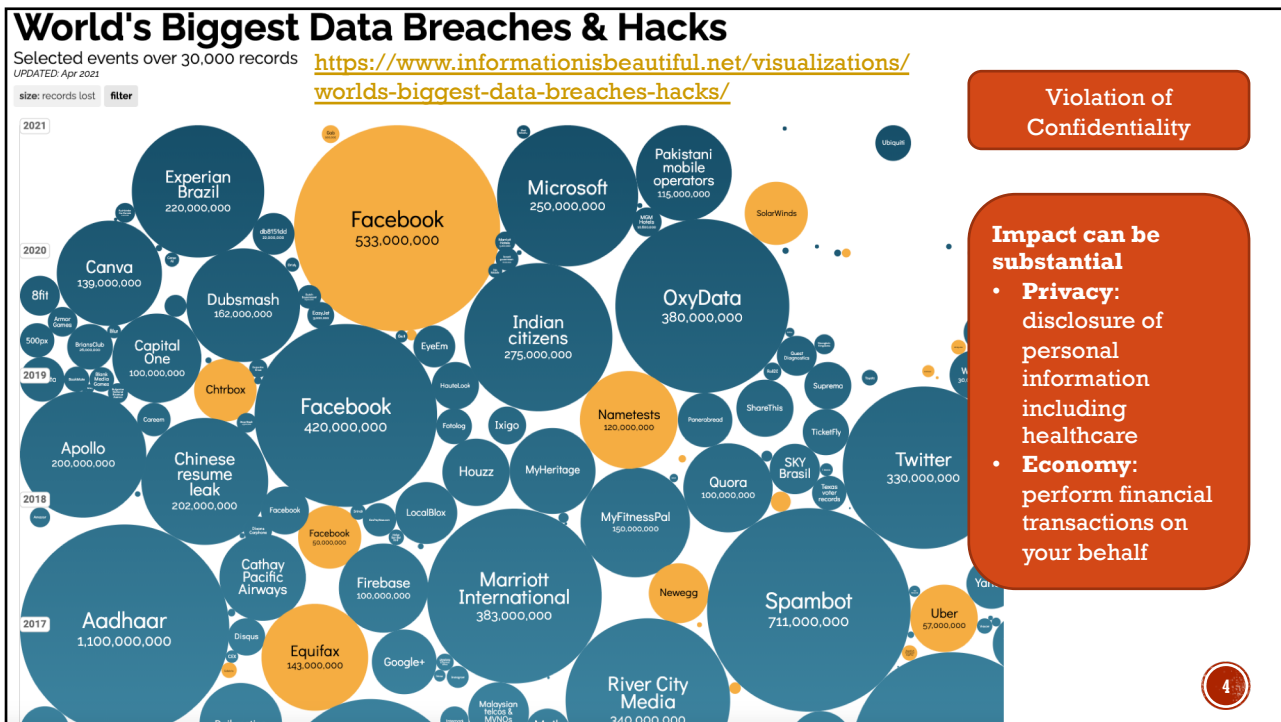
Some real examples

RECALL THE CIA TRIAD

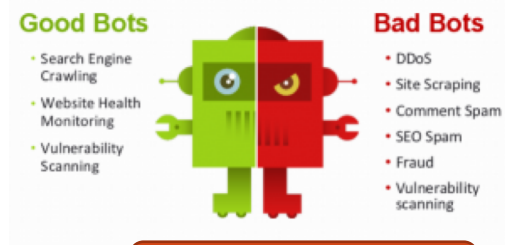
Which property is violated by attacks?

- Confidentiality
 - prevent un-authorised disclosure of information
 - permit authorized sharing of information
- Integrity
 - prevent un-authorised modification of information
 - permit authorized modification of information
- Availability
 - prevent un-authorised withholding of information or services
 - readily permit authorized access to information or services



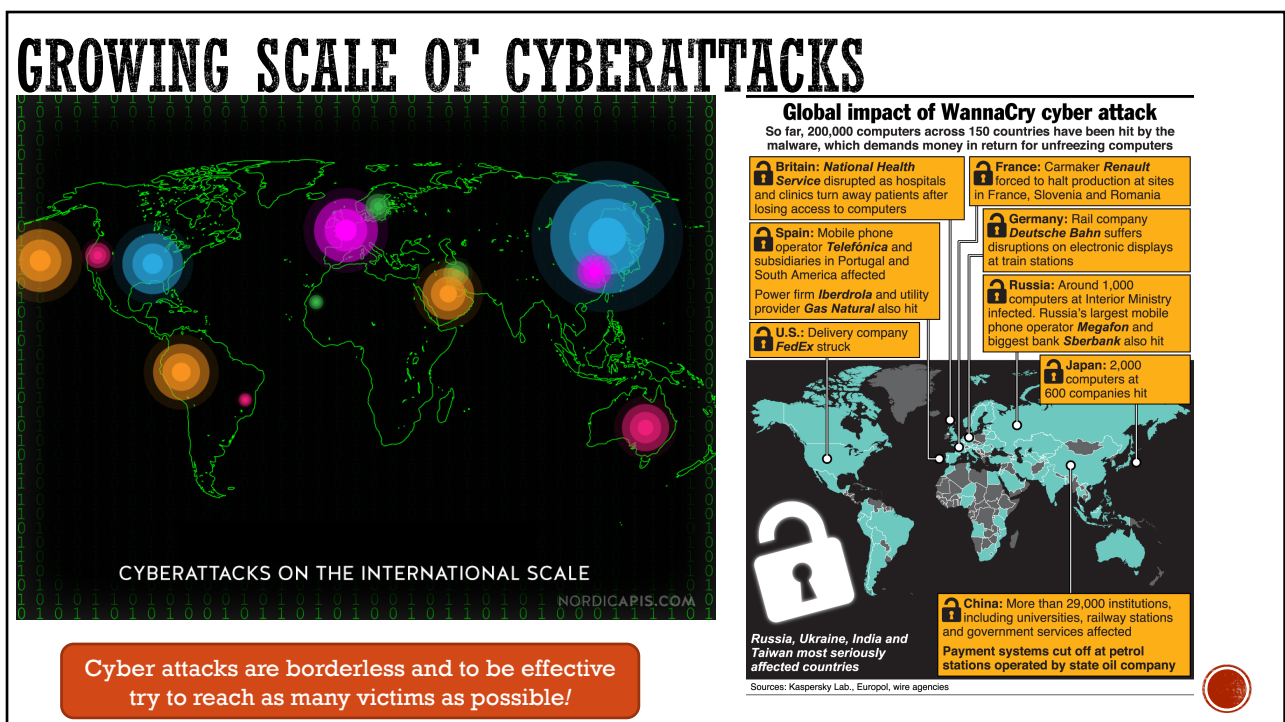
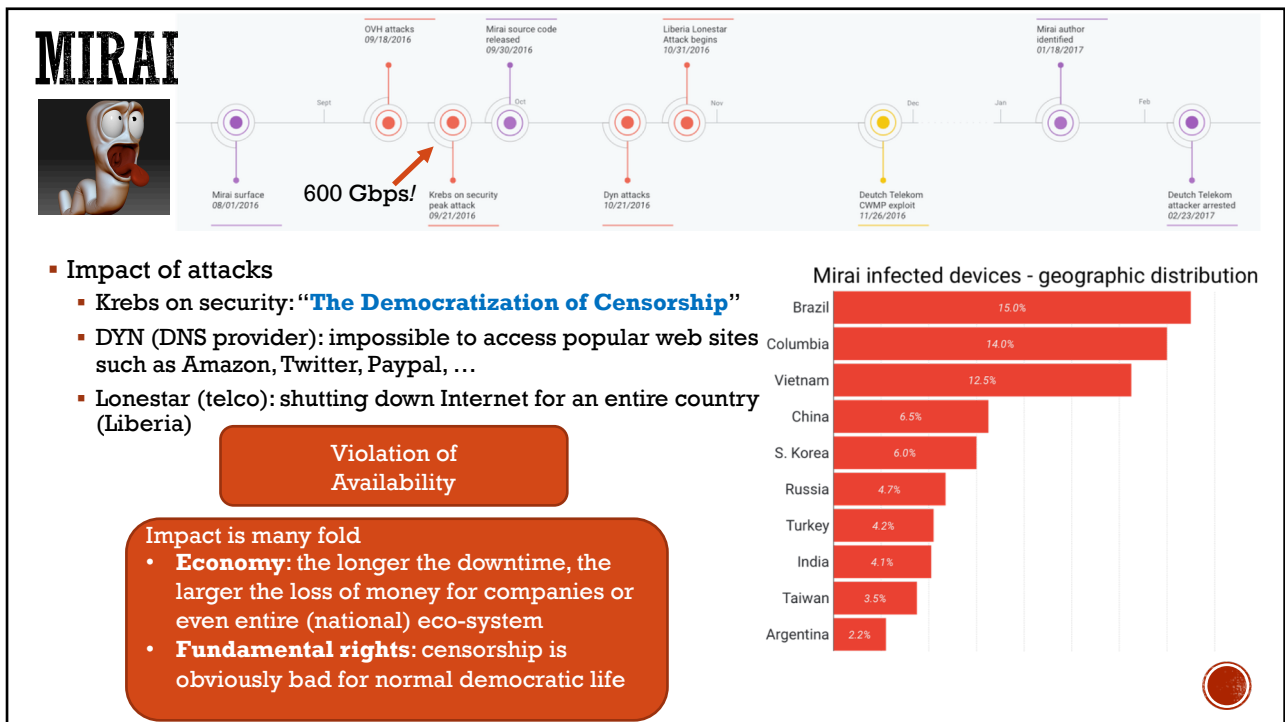


- **Information integrity attack**
 - December 2017: Federal Communication Commission's net neutrality comment form witnessed a miracle... **the dead returning to life**
 - 2 millions identical comments under the name and address of real people... were generated by bots
 - This activity was spotted because users reported that some of the names belonged to their deceased family members and friends!



Violation of Integrity

Impact is on **trustworthiness** of resources and services available online... bots can influence social media by massive posting of messages carrying manipulated information with a negative impact on social/democratic life



Cyber Attack

Anonymity Low Deterrence

The attribution problem

CYBERSECURITY

TECH
MOBILE
SOCIAL MEDIA
ENTERPRISE
CYBERSECURITY
TECH GUIDE

Most hacks take minutes to do — and weeks to discover

Anita Balakrishnan | @MsABalakrishnan
Published 11:24 AM ET Wed, 27 April 2016

“[...] without the fear of being caught, convicted and punished, individuals and organizations will continue to use the Internet to conduct malicious activities.”

Hunker, J., Hutchinson, B., & Margulies, J. (2008). “*Role and Challenges for Sufficient Cyber-Attack Attribution.*” Dartmouth College, United States

“Cyber-attacks can be more dangerous to the stability of democracies and economies than guns and tanks. [...] Cyber-attacks know no borders and no one is immune. This is why, today, the Commission is proposing new tools, including a European Cybersecurity Agency, to help defend us against such attacks.”

European Commission President Jean-Claude Juncker, State of the Union Address, 13 September 2017

European Union Agency for
Network and Information Security

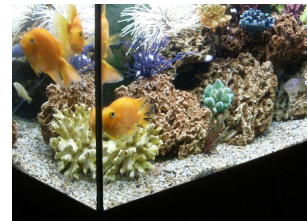
<https://www.enisa.europa.eu>

FURTHER DIFFICULTIES

How a fish tank helped hack a casino

<https://thehackernews.com/2018/04/iot-hacking-thermometer.html>

- Growing attack surface
 - How to evaluate the risks from 3rd party sw?
 - How to evaluate the interdependencies from the infrastructure?
 - How to evaluate the dependencies from the physical world?



- Difficulties in getting **cyber-intelligence information**
 - How to exploit information from other stakeholders to counter threats?
 - How to contribute (in a trusted way) to help other stakeholders?



TWO EXAMPLES OF SECURITY SERVICES

QUESTION: How can we mitigate attacks and reduce impact or, in other words, minimize risks?

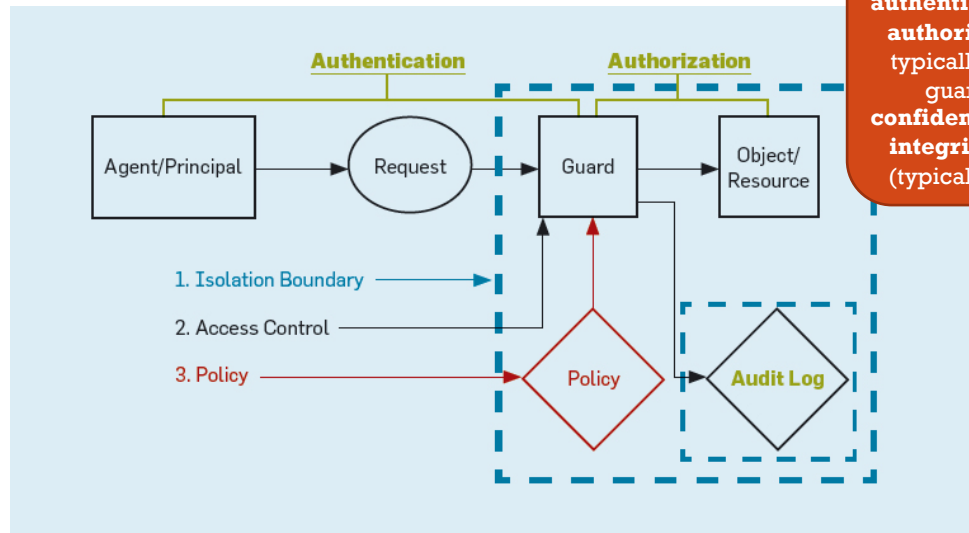
ANSWER: Use security services...

Recall that a **security service** is a capability that supports one, or more, of the security requirements (CIA)

EXAMPLE (1)

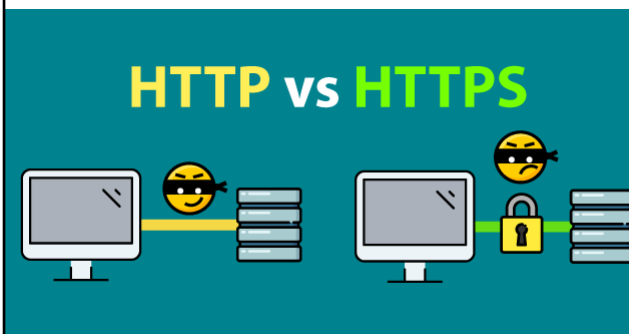


Access control, seen as the combination of **authentication and authorization**, is typically used to guarantee **confidentiality and integrity** of data (typically at rest)



EXAMPLE (2)

The Transport Layer Security (TLS) protocol is used to guarantee confidentiality and integrity of data (in transit) and it is the cornerstone of web security



Helen
HTTP

http://www.example.com
password: abc123



Without password encryption
Hacker see "abc123"



Carol
HTTPS

https://www.example.com
password: abc123



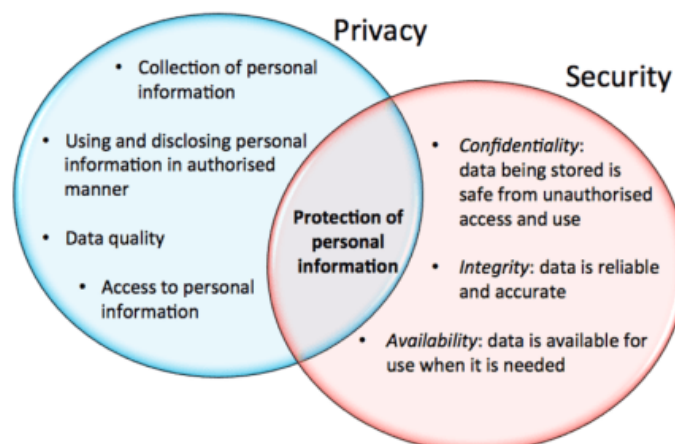
With password encryption
Hacker see "xyaerXzabc"

<https://seopressor.com/blog/http-vs-https/>



SECURITY VS PRIVACY

THEY ARE OVERLAPPING BUT DIFFERENT



TWO FLAVORS OF PRIVACY

- As controlled sharing

Who gets to
see/use/use for a
purpose/transfer to
which information

- As confidentiality

Make the task of
correlating
data/actions
very difficult

16

SOMETIMES SECURITY AND PRIVACY ARE CONFLICTING

- Recall the notion of **non-repudiation** (as part of integrity)
 - Protection against an individual falsely denying having performed a particular action
 - Provides the capability to determine whether a given individual took a particular action such as creating information, sending a message, approving information, and receiving a message
- This is indeed a desirable property when signing a contract or e-commerce application
- In other situations, it may put privacy at risk as it may be the case of e-voting or off-the-record conversations
- The opposite of repudiation is **plausible deniability** aiming to ensure that an instance of communication between computer systems leaves behind no unequivocal evidence of its having taken place

Notice that in this case, a security requirement is seen as
a violation of a privacy requirement and vice versa

17

18

TWO EXAMPLES OF PRIVACY PRESERVING TECHNIQUES

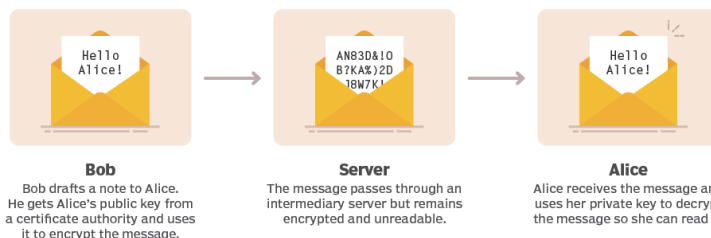
Such techniques roughly correspond to security services when considering privacy... some security services (e.g., some available in cryptography) can also be used as privacy preserving techniques

QUESTION: How can we mitigate attacks and reduce impact or, in other words, minimize risks for privacy?

ANSWER: Use privacy preserving techniques...

EXAMPLE (PRIVACY AS CONFIDENTIALITY)

How end-to-end encryption works



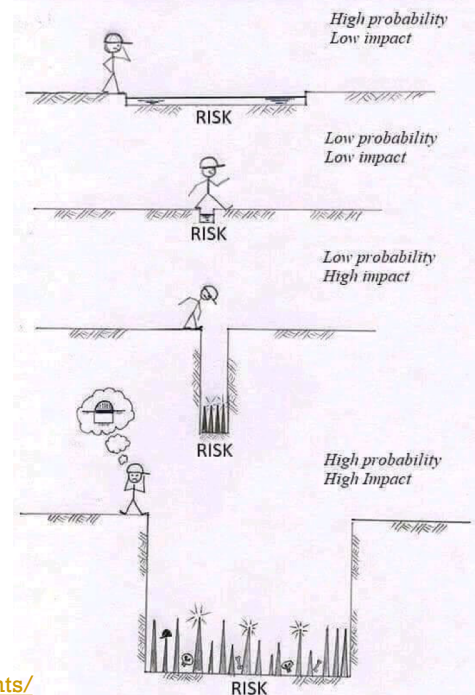
[https://searchsecurity.techtarget.com/definition/end-to-end-encryption-E2EE#:~:text=End%2Dto%2Dend%20encryption%20\(E2EE\)%20is%20a%20method,intended%20recipient%20can%20decrypt%20it](https://searchsecurity.techtarget.com/definition/end-to-end-encryption-E2EE#:~:text=End%2Dto%2Dend%20encryption%20(E2EE)%20is%20a%20method,intended%20recipient%20can%20decrypt%20it)

Impact is always evaluated on the end-user
whose personal data are being processed

RISK BASED PRIVACY



<https://www.i-scoop.eu/gdpr/dpia-data-protection-impact-assessments/>



GENERAL DATA PROTECTION REGULATION (GDPR) OVERVIEW

Tough penalties:
fines of up to

4% of annual global
revenue

or

€20 million,
whichever is **greater**.



The regulation also applies to **non-EU companies** that process personal data of individuals in the EU.



The **international transfer of data** will continue to be governed under EU GDPR rules.

The **definition of personal data** is now broader and includes identifiers such as



genetic



mental



cultural



economic



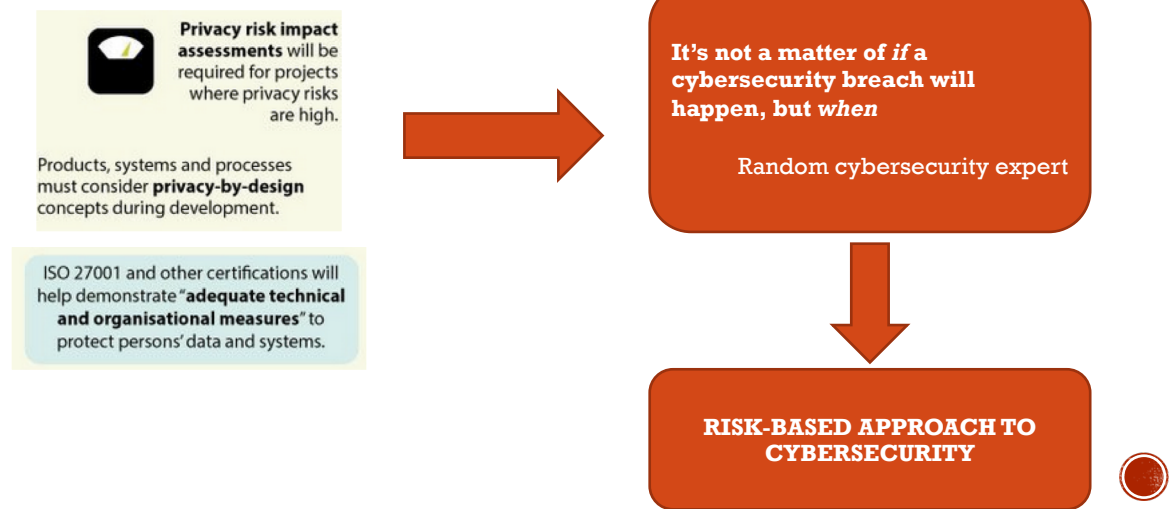
social identity.

Pictures taken from infographics at <https://www.pinterest.fr/pin/396739048415981377/>



GENERAL DATA PROTECTION REGULATION (GDPR)

FOCUS



SECURITY AND HUMAN FACTORS



USABLE SECURITY

<https://csrc.nist.gov/projects/usable-cybersecurity>



Position	Worst passwords of 2020	Password
1. ↑ (2)		123456
2. ↑ (3)		123456789
3. (new)		picture1
4. ↑ (5)		password
5. ↑ (6)		12345678
6. ↑ (17)		111111
7. ↑ (18)		123123
8. ↓ (1)		12345
9. ↑ (11)		1234567890
10. (new)		senha

<https://www.zdnet.com/article/the-worst-passwords-of-2020-show-we-are-as-lazy-about-security-as-ever/>

AWARENESS: AN EXAMPLE

Treat your passwords like your underwear

Change them regularly

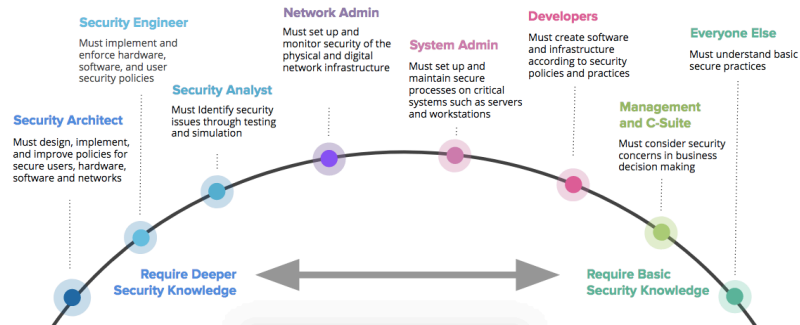
Keep them off your desk

Never share them with anyone

<https://readgroup.co.uk/news/data-protection-why-passwords-are-like-pants/>

Who needs Cybersecurity training?

The full range of learners who benefit from Cybersecurity training

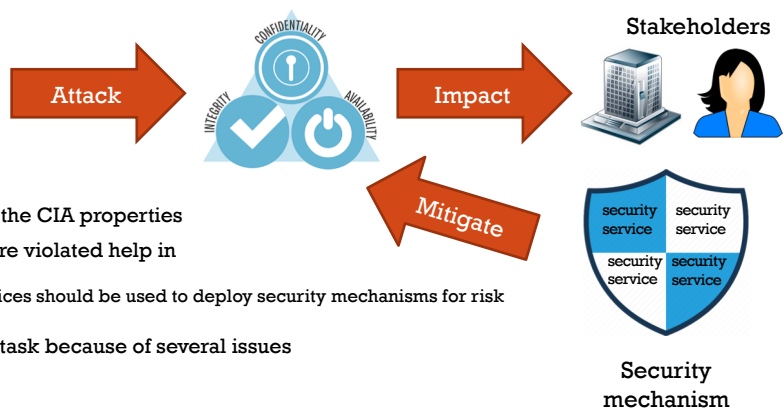


SECURITY TRAINING IS INCREASINGLY NEEDED FOR MORE AND MORE IT PROFESSIONALS

- IT professionals are increasingly taking decisions with security (and privacy) consequences
- On average, they are not trained to do so and this results in a weak security posture that offer an "easy lunch" to attackers



WRAP-UP



- Attacks violate one or more of the CIA properties
- Identifying which properties are violated help in
 - understanding the impact and
 - identifying which security services should be used to deploy security mechanisms for risk mitigation
- Ensuring security is a difficult task because of several issues
 - attribution
 - scale of and borderless attacks
 - growing attack surface
 - lack of collaboration among victims
- Security and privacy overlaps but are different and sometimes conflicting
- Privacy preserving techniques are relevant also from a legal point of view
 - The GDPR encapsulates a risk based approach to privacy
- Security is not purely technical, human factors play a crucial role
 - Hence the importance of security awareness and security training to improve the security posture

